

Access Control Policy V4.2

Document Control

Field	Details
Document Title	Access Control Policy
Document ID	SEC-POL-003
Version	4.2
Effective Date	October 1, 2024
Review Date	October 1, 2025
Document Owner	Chief Information Security Officer (CISO)
Author	Security & Identity Management Team
Approver	CISO + CDO + CIO
Total Pages	20 pages
Classification	INTERNAL
Regulatory Context	NDMO Domain 5 (Data Security), NCA ECC 5-2-1 throu

Version History

Version	Date	Changes	Approved By
1.0	March 2021	Initial policy release	CISO
2.0	September 2021	Added MFA requirements	CISO + CIO
3.0	April 2023	Privileged Access Management (CyberArk) implementa	CISO
4.0	January 2024	Zero Trust principles, FIDO2 for admins	CISO + CDO
4.1	June 2024	Updated UAR frequency (annual → quarterly)	CISO
4.2	October 2024	Added remote access VPN controls, updated password	CISO

Table of Contents

[illegible]

- CISO: Mohammed Al-Qahtani (accountable for policy enforcement)
- Identity & Access Management (IAM) Team: 8 FTEs (responsible for operations)
- Data Owners: Business unit leaders (responsible for access approval)

2. OBJECTIVE & SCOPE

2.1 Objective

The objective of this policy is to:

1. Prevent Unauthorized Access: Ensure that only authenticated and authorized users can access Company A's systems, data, and facilities
2. Enforce Least Privilege: Grant users the minimum access rights necessary to perform their job functions
3. Enable Accountability: Maintain comprehensive audit trails of all access activities for forensic investigation and compliance reporting
4. Support Compliance: Meet regulatory requirements from NDMO, NCA, PDPL, and ISO 27001

2.2 Scope of Applicability

This policy applies to:

Personnel:

- All 850 employees (full-time, part-time)
- 120 contractors and vendors with system access
- 12 executives (Board members, C-suite)
- Third-party service providers (cloud vendors, managed service providers)

Systems:

- On-Premise Systems: Epic EHR, Oracle Exadata, SAP HR, Philips PACS
- Cloud Systems: Azure (IaaS, PaaS, SaaS), Microsoft 365, Salesforce
- Network Infrastructure: Switches, routers, firewalls, VPN gateways
- Endpoints: Laptops, desktops, mobile devices (iOS, Android)
- Physical Facilities: Data centers, server rooms, network closets, offices

Environments:

- Production: Live patient data, financial transactions
- Non-Production: Development, testing, training environments

2.3 Out of Scope

The following are not covered by this policy (separate policies apply):

- Data classification and handling → See: Data Classification Framework v3.5
- Encryption standards → See: Encryption Standards v1.6
- Incident response procedures → See: Security Incident Response Plan v3.0
- Vendor security assessments → See: Third-Party Risk Management Policy v2.1

3. PRINCIPLES OF ACCESS CONTROL

Company A follows five foundational principles for access control, aligned with industry best practices (NIST SP 800-53, ISO 27001, COBIT 5):

3.1 Least Privilege

Definition: Users are granted the minimum access rights necessary to perform their assigned job duties—nothing more, nothing less.

What This Means in Practice:

- A nurse can view patient records in their assigned clinic, but cannot access financial billing data
- A database administrator (DBA) can manage database performance, but cannot access patient medical records (data encrypted at rest, keys managed separately)
- A finance analyst can generate reports from Oracle EBS, but cannot modify chart of accounts or post journal entries

Implementation:

- Default Deny: All access is denied by default; explicit grants are required
- Role-Based Access Control (RBAC): Users are assigned to predefined roles with specific permissions (see Section 5)
- Just-in-Time (JIT) Access: For privileged operations, access is granted on-demand and expires after defined period (e.g., 4 hours)

Example - Violation Prevented:

- ■ **WRONG:** New employee is added to "Domain Admins" group "to make things easier"
- ■ **CORRECT:** New employee is assigned to role-specific group (e.g., "Finance_Report_Viewers") with read-only access to finance dashboards

3.2 Need-to-Know

Definition: Access to Confidential or Secret data (per Data Classification Framework) is granted only if the user has a legitimate business requirement, approved by the Data Owner.

What This Means in Practice:

- Patient medical records are accessible only to healthcare providers involved in the patient's care
- Employee salary data is accessible only to HR and Finance personnel with signed confidentiality agreements
- Strategic planning documents are accessible only to executives and authorized consultants

Implementation:

- Data Owner Approval: All access requests for Confidential/Secret data require Data Owner approval (in addition to manager approval)
- Purpose Justification: Access requests must include business justification (e.g., "Required to generate Q4 financial audit report")
- Time-Bound Access: Access for temporary needs (e.g., external auditor) expires after defined period (e.g., 90 days)

3.3 Segregation of Duties (SoD)

Definition: No single user should have conflicting responsibilities that could enable fraud, error, or abuse.

What This Means in Practice:

- The person who creates a vendor in the ERP system cannot be the same person who approves payments to that vendor
- The person who develops code cannot be the same person who deploys to production (requires peer review)
- The person who performs a backup cannot be the same person who deletes source data (to prevent data destruction)

Implementation:

- SoD Matrix: Documented matrix of 45 critical SoD conflicts (see Appendix B)
- Automated Detection: SailPoint Identity Governance tool scans for SoD violations daily
- Compensating Controls: If SoD violation is unavoidable (e.g., small team), implement compensating controls (e.g., enhanced monitoring, dual approval)

Example SoD Conflicts (Top 3):

Conflicting Permission 1	Conflicting Permission 2	Risk
Create Vendor (Oracle EBS)	Approve Payment (Oracle EBS)	Fraudulent vendor creation + payment
Modify User Access (AD Admin)	Approve Access Request (IAM Admin)	Unauthorized privilege escalation
Access Patient Records (Epic)	Disable Audit Logging (System Admin)	Unauthorized access without detection

3.4 Zero Trust Architecture

Definition: "Never trust, always verify." No user or device is inherently trusted, even if inside the corporate network. Every access request is authenticated, authorized, and encrypted.

What This Means in Practice:

- No more "trusted internal network" vs. "untrusted external network" distinction
- Users connecting from office network undergo same authentication as users connecting from home WiFi
- All access decisions based on real-time context: user identity, device posture, location, risk score

Implementation (5 Pillars of Zero Trust):

1. Verify Explicitly: Authenticate and authorize based on all available data points

- MFA required for all access (no exceptions)
- Device compliance check (antivirus updated, OS patched, disk encrypted)
- Risk score calculation (e.g., login from new country → elevated risk → step-up authentication)

2. Use Least Privilege Access: Grant minimum required access, just-in-time

- Role-based access with time-bound elevation
- Privileged Identity Management (PIM) for admin roles

3. Assume Breach: Design systems as if attacker is already inside network

- Micro-segmentation (network isolation between critical systems)
- Lateral movement detection (alert if user jumps from HR system to Finance system)

4. Inspect and Log Everything: Continuous monitoring and logging

- All authentication events logged to SIEM (Splunk)
- Real-time anomaly detection (e.g., 50 failed login attempts in 5 minutes)

5. Encrypted Everywhere: All data encrypted in transit and at rest

- TLS 1.3 for all API calls
- AES-256 for databases

Zero Trust Maturity (Company A Status: Level 3 - "Advanced"):

- Level 1: Traditional (perimeter-based security) ■
- Level 2: Initial (MFA implemented, but trust after authentication) ■
- Level 3: Advanced (conditional access, device compliance, micro-segmentation) ■ Current
- Level 4: Optimal (AI-driven risk scoring, automated response) ■ Target 2026

3.5 Defense in Depth

Definition: Implement multiple layers of security controls so that if one layer fails, others still provide protection.

Access Control Layers (7 Total):

Layer 1: PERIMETER DEFENSE (Firewall, VPN)

↓

Layer 2: NETWORK SEGMENTATION (VLANs, micro-segmentation)

↓

Layer 3: IDENTITY & AUTHENTICATION (Azure AD, MFA)

↓

Layer 4: AUTHORIZATION (RBAC, data owner approval)

↓

Layer 5: APPLICATION CONTROLS (ABAC - attribute-based access)

↓

Layer 6: DATA ENCRYPTION (AES-256 at rest, TLS 1.3 in transit)

↓

Layer 7: MONITORING & DETECTION (SIEM, SOC, anomaly detection)

Example Scenario: Attacker tries to access patient database

1. Layer 1: Firewall blocks direct internet access to database port (1521)
2. Layer 2: Database server on isolated VLAN, reachable only from app server
3. Layer 3: Application requires Azure AD authentication + MFA
4. Layer 4: User role checked (must be in "Clinical_Staff" group)
5. Layer 5: Application checks attribute (user must be assigned to patient's clinic)
6. Layer 6: Data encrypted; database connection uses TLS 1.3
7. Layer 7: SIEM logs access; anomaly detection flags if user accesses 100+ records in 5 minutes

Result: Even if attacker compromises one layer (e.g., steals password), they still face 6 additional barriers.

4. USER ACCESS MANAGEMENT (LIFECYCLE)

Company A follows a Joiner-Mover-Leaver (JML) framework for managing user access throughout the employment lifecycle.

4.1 Joiner (New Hire / New Contractor)

Trigger: HR System (SAP SuccessFactors) creates new employee record → triggers automated workflow

Step-by-Step Process:

Phase 1: Pre-Boarding (5 Business Days Before Start Date)

1. HR: Completes employee profile in SAP SuccessFactors
 - Fields: Name, National ID, Job Title, Department, Manager, Start Date
2. Automated Workflow: Azure Logic App triggers based on new employee record
3. IT Provisioning: Automated creation of:
 - Azure AD Account: `firstname.lastname@companya.gov.sa`
 - Email Mailbox: Microsoft 365 (50 GB quota)
 - Birthright Access: Systems accessible to all employees
 - Microsoft Teams
 - SharePoint Intranet
 - Employee Self-Service Portal

SLA: 3 business days before start date

Phase 2: Day 1 (First Day of Employment)

4. IT Support: Provisions physical assets
 - Laptop (Dell Latitude 5420, encrypted with BitLocker)
 - YubiKey 5 NFC (FIDO2 hardware token for MFA)
 - Badge (for physical access to office)

5. Manager: Submits Access Request Form (Appendix A) for role-specific systems
 - Example: Physician needs Epic EHR access
 - Approval workflow: Manager → Data Owner (Chief Medical Officer) → IT
6. IT Provisioning: Grants role-specific access within 4 hours

SLA: Same-day provisioning for standard roles

Phase 3: Access Confirmation (Day 2-5)

7. IT Support: Emails new employee with:
 - Welcome message
 - Login instructions
 - Link to mandatory training (Information Security Awareness - 2 hours online)
8. Employee: Completes training within 30 days (tracked in LMS)
9. Manager: Confirms employee can access all required systems

Compliance Metric (Q4 2024): 96% of new hires provisioned on time (target: 95%)

4.2 Mover (Job Transfer / Role Change)

Trigger: HR System updates employee record (Department, Job Title, or Manager change)

Process:

1. HR: Updates employee record in SAP SuccessFactors
2. Automated Alert: IAM Team receives notification of role change
3. Access Review:
 - Old Manager: Reviews and confirms which access should be revoked
 - New Manager: Submits Access Request Form for new role requirements
4. IT Provisioning:
 - Revoke: Old access removed within 24 hours of role change effective date
 - Grant: New access provisioned within 2 business days
5. Overlap Period (Optional): For critical roles (e.g., manager handover), old access may be retained for 5 business days with explicit approval from CISO

Key Rule: No automatic carry-over of access. All access must be justified for new role.

Example - Violation Prevented:

- Employee transfers from Finance to HR
- ■ WRONG: Keep Oracle EBS Finance access "just in case they need to help Finance team"
- ■ CORRECT: Revoke all Finance access, grant HR systems (SAP HR, payroll portal)

Compliance Metric (Q4 2024): 88% of access changes completed within SLA (target: 95%) - Gap identified, remediation underway

4.3 Leaver (Termination / Contract End)

Trigger: HR System marks employee as "Terminated" or "Contract End Date Reached"

Process:

Voluntary Termination (Resignation)

1. HR: Sets termination date in SAP SuccessFactors
2. Automated Workflow: Scheduled job runs daily at 5:00 PM to disable accounts for employees whose last day is today
3. Access Disabled:
 - Azure AD account: Disabled (not deleted) - prevents login
 - VPN access: Revoked
 - Physical badge: Deactivated
4. Data Backup: Manager has 30 days to request backup of employee's email and files (stored in eDiscovery archive)
5. Account Deletion: After 90 days, account is permanently deleted (per Data Retention Policy)

Involuntary Termination (Dismissal for Cause)

1. HR: Notifies CISO and IT Security Lead (via phone call, not email)
2. Immediate Access Revocation: Within 15 minutes
 - Azure AD account disabled
 - VPN disconnected
 - Remote wipe initiated on company laptop (if offsite)
 - Physical badge deactivated
3. Notification: HR conducts termination meeting with employee after access is revoked (prevents sabotage)
4. Asset Collection: Security escort employee to collect personal belongings, surrender laptop and badge

SLA:

- Voluntary: Access disabled by 5:00 PM on last working day
- Involuntary: Access disabled within 15 minutes of HR notification

Compliance Metric (Q4 2024): 100% of terminations processed on time (target: 100%) ■

4.4 Access Request Process

When to Submit Access Request:

- New hire needs role-specific access (beyond birthright)
- Existing employee needs access to new system
- Temporary access for project work or audit

Access Request Form (see Appendix A for full form):

Required Fields:

1. Requestor Information: Name, Department, Manager
2. Access Required: System Name, Role/Group, Justification
3. Duration: Permanent or Temporary (with end date)
4. Business Justification: Why is this access required? (minimum 50 characters)
5. Approvals Required:
 - Manager: Confirms business need
 - Data Owner: Approves access to Confidential/Secret data
 - IT: Provisions access

Approval Workflow (Average 3 Business Days):

Employee submits request (ServiceNow)

↓

Manager approval (1 business day SLA)

↓

Data Owner approval (1 business day SLA - only for sensitive data)

↓

IT provisioning (1 business day SLA)

↓

Confirmation email sent to employee

SLA by Priority:

- Urgent (business-critical, approved by CISO): Same day
- High (patient care impact): 1 business day
- Normal (standard request): 3 business days
- Low (nice-to-have): 5 business days

2024 Performance:

- Total Requests: 3,200
- Approved: 2,950 (92%)
- Rejected: 150 (5%)
- Withdrawn: 100 (3%)
- Average Fulfillment Time: 2.8 business days (target: 3 days) ■

4.5 Emergency Access

Definition: Access granted outside normal approval workflow for urgent business needs (e.g., patient safety, data breach response, system outage).

When Emergency Access is Allowed:

- Patient Safety: Physician needs access to patient record for emergency treatment
- Incident Response: Security analyst needs temporary elevated access to investigate breach
- Business Continuity: Key employee is unavailable, backup needs temporary access to critical system

Process:

1. Requester: Calls IT Service Desk (24/7 hotline: 800-123-4567)

2. IT Service Desk: Verifies identity (asks security questions)
3. Approval: IT Service Desk Lead grants temporary access (valid for 4 hours)
4. Notification: CISO and Data Owner notified via SMS
5. Post-Event Review: Access activity reviewed within 24 hours; requester must submit formal Access Request Form within 2 business days to retroactively justify access

Audit Trail: All emergency access events logged in SIEM with flag for compliance review

2024 Usage: 42 emergency access grants (average 3.5/month) - all reviewed, zero violations found

5. ROLE-BASED ACCESS CONTROL (RBAC)

5.1 RBAC Model Overview

Company A uses Role-Based Access Control (RBAC) to simplify access management. Instead of granting permissions individually to each user, we assign users to roles, and roles have predefined permissions.

RBAC Benefits:

- Consistency: All users in same role have same access
- Scalability: Easier to manage 50 roles than 850 individual user permissions
- Auditability: Clear mapping of role → permissions for compliance

RBAC Hierarchy (3 Levels):

Level 1: FUNCTIONAL ROLES (Department-based)

- Clinical Staff
- Finance Team
- HR Team
- IT Operations
- Executive Leadership

Level 2: JOB-SPECIFIC ROLES (Granular)

- Physician
- Nurse
- Financial Analyst
- Database Administrator
- Chief Data Officer

Level 3: PERMISSION SETS (Technical)

- Epic_Physician_Full_Access
- Oracle_EBS_Readonly
- Azure_Contributor
- SAP_HR_Admin

5.2 Standard Roles (Pre-Defined)

Company A maintains 72 standard roles across 8 systems. Below are examples:

Clinical Roles (Epic EHR)

Role Name	Description	Permissions	# Users
Physician	Full patient care access	Read/Write patient records, Order labs/imaging, e-Pre	820
Nurse	Care coordination	Read patient records, Document care, Administer med	450
Medical Coder	Billing/coding	Read diagnoses, Assign ICD-10/CPT codes	25
Receptionist	Patient check-in	Read demographics, Schedule appointments	90

Finance Roles (Oracle EBS)

Role Name	Description	Permissions	# Users
Financial Analyst	Reporting/analysis	Read GL, AP, AR; Generate reports	15
Accounts Payable Clerk	Vendor payments	Create invoices, Match POs, Submit payments	8
General Ledger Accountant	Journal entries	Post journals, Reconcile accounts	5
CFO	Executive oversight	Read all financial data, Approve budgets	1

5.3 Custom Roles (On-Demand)

When Standard Roles Are Not Sufficient:

- Unique job function not covered by standard roles
- Temporary project requires specific permission combination
- Vendor/contractor needs limited access for specific task

Custom Role Request Process:

1. Manager: Submits Custom Role Request Form (via ServiceNow)
2. IAM Team: Reviews request, designs role permissions
3. Data Owner + CISO: Approve role definition
4. IAM Team: Creates role in Azure AD, documents in Role Catalog
5. Ongoing Maintenance: Custom roles reviewed annually; retire if no longer needed

2024 Custom Roles: 18 active (reviewed quarterly)

5.4 Role Assignment Criteria

How Roles Are Assigned:

1. Job Title Mapping: HR job title automatically maps to default role
 - Example: Job Title "Registered Nurse" → Role "Nurse" in Epic
2. Department Mapping: Department determines functional role
 - Example: Department "Finance" → Role "Finance Team" (birthright access to finance intranet)
3. Manager Request: For role-specific access beyond birthright

Role Matrix (Sample - Top 10 Job Titles):

Job Title	Auto-Assigned Roles	Systems
Physician	Physician (Epic), Clinical_Staff	Epic, Philips PACS, Microsoft 365
Nurse	Nurse (Epic), Clinical_Staff	Epic, Microsoft 365
Financial Analyst	Financial_Analyst (Oracle), Finance_Team	Oracle EBS, PowerBI, Microsoft 365
HR Specialist	HR_Specialist (SAP HR), HR_Team	SAP HR, Microsoft 365
Database Administrator	DBA (Privileged), IT_Operations	Oracle Exadata, Azure SQL, CyberArk
Chief Data Officer	CDO (Executive), Data_Governance	All systems (read-only), Archer GRC
Receptionist	Receptionist (Epic), Clinical_Staff	Epic (limited), Microsoft 365
IT Security Analyst	Security_Analyst (Privileged), IT_Ops	CrowdStrike, Splunk, Azure AD, Firewall
Medical Coder	Medical_Coder (Epic), Clinical_Staff	Epic (read-only), Oracle EBS (billing)
CEO	CEO (Executive), Executive_Leadership	All systems (read-only), Executive Dashboard

6. PRIVILEGED ACCESS MANAGEMENT (PAM)

6.1 Definition of Privileged Accounts

Privileged Accounts are user accounts or service accounts with elevated permissions that can:

- Modify system configurations (e.g., change firewall rules)
- Access sensitive data bypassing normal access controls (e.g., DBA reading patient table)
- Create/delete other user accounts (e.g., Active Directory admin)
- Install/uninstall software on servers
- Bypass audit logging or security controls

Types of Privileged Accounts:

Type	Description	Examples	# Accounts
Domain Admin	Full control over Active Directory	Domain Admins, Enterprise Admins	4
Local Admin	Admin rights on specific server	root (Linux), Administrator (Windows)	180

Database Admin (DBA)	Full control over database	Oracle SYS, Azure SQL sa	8
Cloud Admin	Full control over cloud subscription	Azure Owner, AWS Root	6
Application Admin	Full control over application	Epic System Admin, SAP Basis Admin	12
Service Account	Non-human account for app-to-app	Epic_Integration_Service, ADF_ServicePrincipal	4

Total Privileged Accounts at Company A: 255 (30% human, 70% service accounts)

6.2 PAM Requirements

All privileged accounts must comply with the following requirements:

Requirement 1: No Direct Login (Jump Server / Bastion Host)

- Prohibited: Admin logs in directly as root or Administrator
- Required: Admin logs in with personal account, then elevates privileges via:
 - Linux: `sudo` command (logged and audited)
 - Windows: "Run as Administrator" (with justification prompt)
 - Cloud: Azure Privileged Identity Management (PIM) - time-bound elevation

Example Workflow:

1. DBA needs to restart Oracle database
2. Logs in to bastion host with personal account: ahmed.alrashid@companya.gov.sa
3. Requests privileged access via CyberArk: "Request access to Oracle_Prod_DBA role for 4 hours"
4. Manager receives SMS approval request, approves
5. DBA elevates to DBA role for 4 hours, performs task
6. After 4 hours, access automatically expires

Requirement 2: Password Vaulting (CyberArk)

- Prohibited: Storing privileged passwords in Excel, sticky notes, or browser
- Required: All privileged account passwords stored in CyberArk Privileged Access Security (PAS) vault

CyberArk Features:

- Automatic Password Rotation: Passwords changed every 24 hours (for service accounts) or 90 days (for admin accounts)
- Check-Out/Check-In: Admin "checks out" password for temporary use, CyberArk provides temporary password
- Session Recording: All privileged sessions video-recorded (stored 90 days)
- Dual Control: For ultra-sensitive accounts (e.g., Domain Admin), requires approval from 2 people

2024 CyberArk Statistics:

- Accounts Managed: 255
- Password Rotations: 9,200 (automatic)
- Privileged Sessions: 12,500

- Policy Violations: 0 ■

Requirement 3: Privileged Session Monitoring

All privileged sessions on Critical Systems (defined as Tier 1 systems per Data Classification Framework) are:

- Video Recorded: Full keystroke and screen recording
- Real-Time Monitored: SOC analyst can view live session if anomaly detected
- Searchable: Videos indexed by keywords (e.g., "DROP TABLE", "DELETE FROM")

Monitoring Triggers:

- Privileged user logs in from unfamiliar location
- Privileged user accesses sensitive table (e.g., PATIENT_RECORDS)
- Privileged user runs dangerous command (e.g., `rm -rf /`, `DROP DATABASE`)

Response: SOC analyst receives alert, reviews session recording, escalates to CISO if suspicious

Requirement 4: MFA for Privileged Access

All privileged accounts require phishing-resistant MFA:

- ■ Not Allowed: SMS OTP (vulnerable to SIM swapping)
- ■ Required: FIDO2 hardware token (YubiKey 5 NFC) or Microsoft Authenticator push notification

Statistics (Q4 2024):

- Privileged Users with FIDO2: 100% (75/75 users) ■
- Privileged Access Attempts Without MFA: 0 (MFA enforced via Conditional Access Policy)

6.3 Privileged Session Monitoring

Tools:

- CyberArk Privileged Session Manager (PSM): Session recording and monitoring
- Splunk SIEM: Real-time alerting based on privileged activity

Key Monitored Activities:

Activity	Risk Level	Alert Threshold	Response
Login to production database	MEDIUM	> 10 logins/day by same user	SOC reviews pattern
Access to patient records table	HIGH	Any access (requires justification)	CISO notified
DROP/DELETE command on production	CRITICAL	Any occurrence	Immediate CISO escalation + session termination
Password change for privileged account	MEDIUM	Outside CyberArk rotation	SOC investigates (possible compromise)
Privileged login from foreign country	CRITICAL	Any occurrence (Company A is KSA-only)	Session blocked, CISO notified

2024 Incidents:

- Total Alerts: 180
- False Positives: 165 (92%)

- True Positives: 15 (8%)
- 12 = Policy violations (user education provided)
- 3 = Suspicious activity (investigated, no breach confirmed)

6.4 Break-Glass Accounts

Definition: Emergency administrative accounts used only when normal access methods fail (e.g., Azure AD outage, CyberArk unavailable).

Characteristics:

- Stored Offline: Passwords written on paper, sealed in envelope, stored in physical safe (CFO's office)
- Usage: Restricted to emergency scenarios approved by CISO
- Audit: Every use of break-glass account requires incident report within 24 hours
- Rotation: Passwords changed quarterly

Break-Glass Accounts (4 Total):

1. BreakGlass_AzureAD_Admin - Azure AD Global Administrator
2. BreakGlass_Oracle_DBA - Oracle database SYS account
3. BreakGlass_Network_Admin - Firewall/switch admin
4. BreakGlass_Epic_SystemAdmin - Epic EHR system admin

2024 Usage: 2 instances (both legitimate - Azure AD service outage on March 15, resolved in 4 hours)

7. PASSWORD & AUTHENTICATION STANDARDS

7.1 Password Complexity Requirements

All user passwords must meet the following requirements:

Requirement	Standard	Rationale
Minimum Length	12 characters	Resists brute force (time to crack: 200+ years at
Character Mix	Must contain: 1 uppercase, 1 lowercase, 1 number,	Increases entropy
Dictionary Check	Cannot contain common words (checked against 10,000	Prevents weak passwords like "Password123!"
Username Check	Cannot contain username or email	Prevents predictable passwords
History	Cannot reuse last 10 passwords	Prevents password cycling
Expiration	90 days for standard users, 60 days for privileged	Limits window of compromise
Minimum Age	1 day (prevents immediate password change back to	Enforces history rule

Password Strength Meter: Azure AD Password Protection provides real-time feedback during password creation (Weak / Fair / Good / Strong)

7.2 Multi-Factor Authentication (MFA)

MFA Requirement: Mandatory for all users (no exceptions)

Supported MFA Methods (in order of security strength):

Rank	Method	Description	Security Level	Usage
1	FIDO2 Hardware Token	YubiKey 5 NFC (USB + NFC)	Phishing-resistant	Privileged users (75)
2	Microsoft Authenticator (Push)	Smartphone app, push notification	Phishing-resistant	Standard users (775)
3	Microsoft Authenticator (TOTP)	Time-based one-time password (6-digit code)	Medium	Backup method
4	Phone Call	Automated call to registered phone	Low (SIM swapping risk)	Emergency backup only
5	SMS OTP	Text message with 6-digit code	■ PROHIBITED for admins	Standard users only (not recommended)

MFA Enrollment:

- Mandatory: All users must enroll MFA within 5 days of account creation
- Grace Period: If MFA not enrolled by Day 5, account locked until enrollment complete
- Backup Method: Users must register 2 MFA methods (primary + backup)

2024 MFA Statistics:

- Enrollment Rate: 99.2% (842/850 users) ■
- MFA Authentication Success Rate: 98.5%
- MFA Failures: 1.5% (mostly user error - "I forgot my phone")

MFA Bypass (Prohibited): No user can bypass MFA, even with CISO approval. For broken/lost device, user must contact IT Service Desk for device re-registration.

7.3 Password Management

Password Reset Process:

Self-Service Password Reset (SSPR)

1. User visits <https://passwordreset.companya.gov.sa>
2. Enters username/email
3. Completes identity verification (2 of 3 required):
 - Answer security questions (3 questions set during enrollment)
 - Verify via MFA (SMS or Authenticator)
 - Provide last 4 digits of National ID + date of birth
4. Creates new password (meeting complexity requirements)
5. New password synced to all systems within 15 minutes (Azure AD Connect)

SSPR Statistics (2024):

- Total Resets: 1,200
- Success Rate: 94%
- Average Time: 3.5 minutes

Assisted Password Reset (IT Service Desk)

If SSPR fails (e.g., user forgot security answers and lost MFA device):

1. User calls IT Service Desk: 800-123-4567
2. Service Desk agent verifies identity (asks 5 security questions + manager confirmation)
3. Agent resets password and sends temporary password via SMS
4. User must change password at next login

SLA: 30 minutes (during business hours)

7.4 Account Lockout Policy

Purpose: Prevent brute-force password guessing attacks

Lockout Settings:

- Threshold: Account locks after 5 failed login attempts within 10 minutes
- Lockout Duration: 30 minutes (auto-unlock) OR user can call IT Service Desk for immediate unlock
- Lockout Reset Counter: Resets after 10 minutes of no failed attempts

Administrator Lockout: Privileged accounts lock after 3 failed attempts (stricter threshold)

2024 Lockout Events: 450 total (average 1.3/day) - 98% due to user error, 2% suspicious (investigated)

8. REMOTE ACCESS CONTROL

8.1 VPN Access Requirements

When VPN is Required:

- Accessing Company A systems from outside office network (home, cafe, travel)
- Accessing on-premise systems (Epic EHR, Oracle Exadata, SAP HR)

VPN Solution: Cisco AnyConnect Secure Mobility Client

VPN Access Requirements:

1. MFA: Required at VPN connection (cannot bypass)
 2. Device Compliance: Endpoint must meet security baseline:
- Antivirus installed and updated (within 7 days)

- OS patches installed (within 30 days)
- Disk encryption enabled (BitLocker for Windows, FileVault for macOS)
- 3. Split Tunneling: Disabled (all traffic routed through VPN to prevent data leakage)
- 4. Idle Timeout: VPN disconnects after 30 minutes of inactivity

VPN Usage Statistics (Q4 2024):

- Unique Users: 520 (61% of staff work remotely at least 1 day/week)
- Average Daily Connections: 180
- Average Session Duration: 4.2 hours
- Connection Failures (Due to Compliance): 35/month (device out of compliance)

8.2 Remote Desktop Protocol (RDP) Controls

RDP Use Case: IT admins connect to servers for maintenance

Security Controls:

1. RDP Gateway: All RDP connections routed through RDP Gateway (no direct RDP to servers)
2. MFA: Required for RDP Gateway access
3. Network-Level Authentication (NLA): Enabled (authentication before RDP session starts)
4. Restricted Source IPs: RDP Gateway accessible only from Company A VPN (not public internet)
5. Session Recording: All RDP sessions to production servers recorded via CyberArk PSM

Prohibited: RDP from home computer directly to Company A server (firewall blocks port 3389 from internet)

8.3 BYOD (Bring Your Own Device) Policy

BYOD Status: Limited support

Allowed:

- Personal smartphone/tablet for email and Microsoft Teams only (via Microsoft Intune MAM - Mobile Application Management)
- No access to Epic EHR, Oracle EBS, or other clinical/finance systems from personal devices

Requirements for BYOD Enrollment:

1. Device Enrollment: Install Microsoft Intune Company Portal app
2. Device Compliance: Meet minimum security baseline (PIN/password, OS version)
3. Conditional Access: Access restricted to Microsoft 365 apps only
4. Remote Wipe: User consents to remote wipe of company data if device is lost/stolen (personal data not affected)

2024 BYOD Enrollment: 120 users (14% of staff) - mostly executives checking email on personal iPhone/iPad

9. PHYSICAL ACCESS CONTROL

9.1 Data Center Access

Data Center Locations:

- Riyadh Primary Data Center: Main facility (Oracle Exadata, Azure Stack HCI)
- Jeddah Secondary Data Center: DR site (backup, disaster recovery)

Physical Access Controls:

Control Layer	Implementation	Compliance Reference
Perimeter Fence	2-meter fence with razor wire, CCTV coverage	ISO 27001 A.11.1.1
Entry Gate	Security guard, vehicle inspection	ISO 27001 A.11.1.2
Building Entry	Badge swipe (RFID card)	ISO 27001 A.11.1.3
Data Center Door	Biometric fingerprint + badge	NCA ECC 5-1-2
Server Cage	Combination lock (code rotated quarterly)	ISO 27001 A.11.1.5
Visitor Escort	Visitors must be escorted at all times, no unescor	ISO 27001 A.11.1.4

Access Logging:

- All physical access events logged (badge swipes, fingerprint scans)
- Logs retained for 90 days, reviewed weekly by Security Manager
- Anomaly detection: Alert if data center accessed outside business hours (unless pre-approved maintenance)

Visitor Process:

1. Visitor must be registered 24 hours in advance (name, National ID, purpose, escort name)
2. Visitor presents ID at entrance, badge issued (red "VISITOR" lanyard)
3. Escort signs visitor log, escorts visitor at all times
4. No cameras/phones allowed in data center (surrendered at entrance)
5. Visitor badge returned, exit logged

2024 Data Center Access Stats:

- Total Access Events: 2,400 (average 10/day)
- Authorized Employees: 25
- Visitors: 45 (vendors, auditors)
- Anomalies: 3 (false alarms - employee forgot to log maintenance window)

9.2 Office and Workspace Access

Office Locations:

- Riyadh Main Campus (5 buildings)
- Jeddah Branch (1 building)
- Dammam Branch (1 building)

Access Controls:

- Badge Swipe: Required to enter building (RFID badge)
- Reception Desk: Security guard validates visitors
- Executive Floor: Additional badge swipe required for access to executive offices (confidential discussions)

Badge Management:

- Issuance: IT Security issues badge on Day 1 of employment
- Return: Badge surrendered on last day of employment
- Lost Badge: Report immediately, badge deactivated, replacement fee SAR 100

9.3 Clean Desk and Clear Screen Policy

Clean Desk Policy:

- Confidential documents must be locked in drawer or cabinet when not in use
- No confidential documents left on printer (enforce print-release feature - user must badge at printer to release print job)
- End of Day: All documents removed from desk, locked away

Clear Screen Policy:

- Screen Lock: Computer automatically locks after 10 minutes of inactivity
- Manual Lock: User must manually lock (Windows: Win+L, macOS: Ctrl+Cmd+Q) when leaving desk
- Privacy Screens: Required for laptops used in public spaces (cafes, airports)

Enforcement: Security team conducts random "Desk Audits" monthly - 20 desks checked. Findings reported to managers. Repeat offenders receive formal warning.

2024 Desk Audit Results:

- Audits Conducted: 12 (monthly)
- Desks Checked: 240
- Violations Found: 18 (7.5%) - mostly documents left on desk overnight
- Repeat Offenders: 2 (formal warnings issued)

10. ACCESS REVIEW & RECERTIFICATION

10.1 User Access Review (UAR) Process

Purpose: Ensure users still require the access they have been granted (principle of least privilege requires periodic verification)

Frequency: Quarterly (every 3 months)

Process:

1. IAM Team: Generates access reports from Azure AD, Epic, Oracle, SAP (full list of users and their permissions)
2. Manager Distribution: Reports sent to managers via email (each manager receives report for their direct reports)
3. Manager Review: Manager reviews each user's access and makes decision:
 - Keep: Access still required, no action needed
 - Remove: Access no longer required, schedule revocation
 - Modify: Access level needs adjustment (e.g., downgrade from write to read-only)
4. Manager Deadline: 10 business days to complete review
5. Escalation: If manager does not complete review by deadline:
 - Day 11: Reminder email sent
 - Day 15: Escalation to manager's director
 - Day 18: Manager's own access suspended until review completed (strong incentive)
6. IT Execution: Access revocations processed within 5 business days

2024 UAR Statistics:

- Reviews Conducted: 4 (Q1, Q2, Q3, Q4)
- Total Users Reviewed: $850 \times 4 = 3,400$ user-reviews
- Access Revocations: 280 (8.2% of total access reviewed)
- On-Time Completion: 98% (target: 95%) ■
- Late Completions: 2% (escalation process triggered)

10.2 Privileged Account Review

Frequency: Monthly (stricter than standard UAR due to risk)

Process:

1. CISO: Reviews list of all privileged accounts (255 accounts)
2. Verification: Confirms each privileged account still has business justification
3. Owner Confirmation: Privileged account owner confirms last use date
4. Dormant Account Check: Accounts unused for 90 days flagged for revocation

2024 Privileged Account Review:

- Total Reviews: 12 (monthly)
- Accounts Reviewed: $255 \times 12 = 3,060$ account-reviews
- Dormant Accounts Removed: 8
- On-Time Completion: 100% ■

10.3 Review Frequency Summary

Review Type	Frequency	Responsibility	SLA
User Access Review (UAR)	Quarterly	Managers	10 business days
Privileged Account Review	Monthly	CISO	5 business days

Service Account Review	Semi-Annually	Application Owners	15 business days
Emergency Access Review	Immediate (post-event)	CISO + Data Owner	24 hours
Segregation of Duties (SoD) Scan	Daily (automated)	IAM Team	Same day (for violations)

11. MONITORING, LOGGING & AUDIT

11.1 Access Logging Requirements

All systems must log the following access events:

Event Type	Required Log Fields	Example
Successful Login	Username, timestamp, source IP, system/app	ahmed.alrashid logged into Epic at 2024-10-15 08:3
Failed Login	Username (attempted), timestamp, source IP, failur	Failed login for ahmed.alrashid at 2024-10-15 08:3
Logout	Username, timestamp, session duration	ahmed.alrashid logged out of Epic at 2024-10-15 17
Privileged Access	Username, privilege escalation method, target syst	ahmed.alrashid elevated to DBA role via CyberArk a
Access Denied	Username, resource requested, denial reason	ahmed.alrashid access denied to Finance Dashboard
Password Change	Username, timestamp, change method (self-service/a	ahmed.alrashid password changed at 2024-10-15 08:0
Account Lockout	Username, timestamp, failed attempt count	ahmed.alrashid account locked at 2024-10-15 09:20:

11.2 Log Retention

Log Type	Retention Period	Storage Location	Compliance Reference
Authentication Logs	2 years	Splunk SIEM	NCA ECC 5-3-9
Privileged Session Recordings	90 days	CyberArk PSM	ISO 27001 A.12.4.3
Physical Access Logs	90 days	Building management system	ISO 27001 A.11.1.3
Access Review Reports	5 years	SharePoint (audit folder)	Internal Audit requirement

11.3 Real-Time Monitoring & Alerts

SIEM Tool: Splunk Enterprise Security

Alert Scenarios (Top 10):

Alert Name	Trigger Condition	Severity	Response
Brute Force Attack	10+ failed logins from same IP in 5 minutes	HIGH	SOC investigates, blocks IP if confirmed
Impossible Travel	User logs in from 2 different countries within 1 hour	CRITICAL	Account suspended, CISO notified
Privileged Account Login from Unrecognized Device	Authn/Deauthn from device not in CyberArk inventory	HIGH	SOC contacts user for verification
After-Hours Access to Critical System	Login to Epic/Oracle outside business hours	MEDIUM	SOC reviews, logs for quarterly UAR
Mass Data Download	User downloads > 1000 patient records in 15 minutes	CRITICAL	Session terminated, CISO + DPO notified
Privileged Command Execution	DROP TABLE, DELETE FROM, rm -rf command on production	CRITICAL	Session recorded, CISO notified immediately
MFA Bypass Attempt	User attempts login without completing MFA challenge	MEDIUM	Login blocked, IT Security notified
Dormant Account Reactivation	Account unused for 90+ days suddenly logged in	MEDIUM	SOC reviews for compromise
SoD Violation Detected	User assigned conflicting roles (e.g., Create + Approve)	CRITICAL	IAM Team removes conflicting role, notifies manager
Break-Glass Account Usage	Emergency admin account used	CRITICAL	CISO notified immediately, incident report required

2024 Alert Statistics:

- Total Alerts: 3,200
- True Positives: 450 (14%)
- False Positives: 2,750 (86%) - continuous tuning to reduce noise
- Average Response Time: 18 minutes (from alert to SOC action)

12. EXCEPTIONS & NON-COMPLIANCE

12.1 Policy Exception Process

When Exceptions Are Allowed:

- Business-critical situation where policy compliance is not technically feasible
- Temporary deviation required for specific project (with compensating controls)
- Regulatory requirement conflicts with policy (policy updated to reflect regulation)

Exception Request Process:

1. Requestor: Submits Policy Exception Request Form (via ServiceNow)
 - Business justification (why exception is needed)
 - Risk assessment (what security risk is introduced)
 - Compensating controls (how risk will be mitigated)
 - Duration (temporary or permanent exception)
2. Security Review: CISO reviews request, assesses risk
3. Approval Authority:
 - Low Risk: CISO approves
 - Medium/High Risk: CISO + CDO + CIO approve (Risk Committee)
4. Monitoring: Exceptions tracked in risk register, reviewed quarterly

2024 Exception Requests:

- Submitted: 12
- Approved: 8 (67%)
- Rejected: 4 (33%) - insufficient justification or excessive risk

Active Exceptions (as of Q4 2024): 3

1. External auditor access to production database (read-only) for 90 days - Approved with compensating control: Session recording + SOC monitoring
2. Legacy application unable to support MFA - Approved with compensating control: Network isolation (accessible only from specific VLAN)
3. Service account password rotation extended to 180 days (vendor limitation) - Approved with compensating control: Enhanced logging + monthly review

12.2 Non-Compliance Consequences

Violations are categorized by severity:

Severity 1: Critical (Immediate Action Required)

Examples:

- Sharing privileged account password with another user
- Disabling security controls (e.g., disabling antivirus, tampering with logs)
- Unauthorized access to sensitive data (Confidential/Secret)

Consequences:

- Immediate: Account suspended, manager notified, HR investigation initiated
- Outcome: Formal written warning (first offense) or termination (repeat offense)

Severity 2: High (Formal Warning)

Examples:

- Failing to lock screen when leaving desk (clean desk policy violation)
- Sharing password with colleague (even if non-privileged)
- Bypassing access request process (asking IT to grant access without manager approval)

Consequences:

- First Offense: Manager counseling + security awareness training (mandatory 1-hour session)
- Second Offense: Formal written warning
- Third Offense: Escalation to HR, potential termination

Severity 3: Medium (Education & Remediation)

Examples:

- Weak password (not meeting complexity requirements)
- Late completion of User Access Review (UAR)

- Using personal USB drive on company laptop (data leakage risk)

Consequences:

- First Offense: Email reminder + security awareness tip
- Repeat Offenses: Manager notified, training required

2024 Violation Statistics:

- Severity 1 (Critical): 2 incidents
 - 1 = Sharing password (employee terminated)
 - 1 = Unauthorized database access (formal warning issued, access revoked)
- Severity 2 (High): 18 incidents (mostly clean desk violations)
- Severity 3 (Medium): 120 incidents (mostly weak passwords, UAR delays)

Trend: Violations decreased 35% from 2023 (due to increased awareness training)

APPENDIX A: ACCESS REQUEST FORM

Form ID: AR-001

Submit via: ServiceNow (IT Service Portal → Access Management → New Access Request)

Section 1: Requestor Information

Full Name: _____
Employee ID: _____
Department: _____
Job Title: _____
Manager Name: _____
Email: _____
Phone: _____

Section 2: Access Details

System/Application Name: _____ (e.g., Epic EHR, Oracle EBS, PowerBI)

Access Type (select one):

- ☒ New Access (first-time access to system)
- ☒ Additional Access (request additional permissions to existing system)
- ☒ Temporary Access (specify end date): _____

Role/Permission Requested: _____ (e.g., "Physician", "Financial Analyst Read-Only")

Section 3: Business Justification

Why is this access required? (Minimum 50 characters, be specific):

Is this access to Confidential or Secret data? (per Data Classification Framework)

- ☐ Yes (Data Owner approval required)
- ☐ No

If Yes, Data Owner Name:

Section 4: Approvals

Approver	Name	Signature	Date
Manager			
Data Owner (if Confidential/Secret data)			

Section 5: IT Use Only

Request ID: AR-2024-

Received Date:

Provisioned By:

Provisioned Date:

Status: ☐ Approved ☐ Rejected ☐ Pending

APPENDIX B: SEGREGATION OF DUTIES (SOD) MATRIX

Purpose: Prevent fraud and errors by ensuring no single user has conflicting permissions

Sample SoD Conflicts (Top 10 of 45 total):

Conflict ID	Permission 1	Permission 2	Risk	Mitigation
SOD-01	Create Vendor (Oracle EBS)	Approve Payment (Oracle EBS)	Fraudulent vendor + payment	Compensating control: Monthly audit of new
SOD-02	Modify User Access (Azure AD)	Approve Access Request (IAM Manager)	Unauthorized privilege escalation	Automated SoD scan daily; violations auto-re

SOD-03	Access Patient Records (Epic)	Disable Audit Logging (System Admin)	Unauthorized access without detection	Network segmentation; audit logging management
SOD-04	Post Journal Entry (Oracle EBS)	Approve Journal Entry (Oracle EBS)	Unauthorized financial transaction	Workflow enforces maker-checker rule
SOD-05	Modify Pricing (Oracle EBS)	Generate Invoice (Oracle EBS)	Revenue manipulation	Pricing changes require CFO approval
SOD-06	HR Employee Data Entry (SAP HR)	Payroll Processing (SAP HR)	Payroll fraud	Payroll processed by separate Finance team
SOD-07	Database Backup (DBA)	Database Restore (DBA)	Data destruction (backup then delete)	Restore requires 2-person approval (dual control)
SOD-08	Code Commit (Developer)	Production Deployment (DevOps)	Malicious code deployment	Peer review + automated security scan (Sonar)
SOD-09	Incident Response (SOC Analyst)	Security Policy Waiver (CISO)	Cover-up of security incident	Incident response actions logged, reviewed by CISO
SOD-10	Physical Data Center Access (Facilities)	Privileged Account Access (IT Admin)	Physical + logical access = high risk	Badge access logs reviewed weekly; anomalies investigated

Automated SoD Monitoring: SailPoint IdentityIQ scans for violations daily at 3:00 AM. Violations escalated to IAM Team for remediation.

APPENDIX C: GLOSSARY OF TERMS

Term	Definition
Azure AD	Azure Active Directory - Microsoft's cloud-based i
CyberArk	Privileged Access Management (PAM) solution used f
FIDO2	Fast Identity Online 2 - phishing-resistant authen
IAM	Identity and Access Management - processes and tec
MFA	Multi-Factor Authentication - requires 2+ factors
PAM	Privileged Access Management - securing and monito
RBAC	Role-Based Access Control - assigning permissions
SoD	Segregation of Duties - no single user has conflic
SIEM	Security Information and Event Management - centra
SSO	Single Sign-On - login once to access multiple sys
UAR	User Access Review - periodic review of user permi
Zero Trust	Security model: "Never trust, always verify" - no

END OF POLICY

Document Approval:

Role	Name	Signature	Date
Chief Information Security Officer (CISO)	Mohammed Al-Qahtani	[Digitally Signed]	October 1, 2024
Chief Data Officer (CDO)	Dr. Yasser Al-Najjar	[Digitally Signed]	October 1, 2024
Chief Information Officer (CIO)	Nasser Al-Qahtani	[Digitally Signed]	October 1, 2024
Chief Privacy Officer (CPO)	Fatima Al-Zahrani	[Digitally Signed]	October 1, 2024

Official Seal: Company A - Riyadh, Kingdom of Saudi Arabia

Distribution:

- All employees (via email + intranet posting)
- All contractors and vendors with system access
- IT Security Team
- IAM Team
- Data Stewards
- Audit & Compliance Team

Related Policies:

- Data Classification Framework v3.5
- Data Security Strategy 2025-2027 v2.0
- Privacy Policy v5.1
- Security Incident Response Plan v3.0
- Encryption Standards v1.6
- Third-Party Risk Management Policy v2.1